DERECHO INFORMÁTICO · URUGUAY Y EL MUNDO

Ciberdelito, ciberdefensa y privacidad internacional

Marco jurídico uruguayo, cooperación internacional y protección de datos personales.

Ponentes: Sandra Barrera y Matias Bardo

Profesor: Nelson Connio

La pregunta central: ¿Cómo responder cuando el atacante, la víctima, los servidores y los datos están en países distintos?

Delitos, soberanía y datos que cruzan fronteras.



Índice

Contexto

Lámina 3

Ciberdelitos en Uruguay

Láminas 4–9

Cooperación internacional

Láminas 10–12

Ciberdefensa y soberanía

Láminas 13–15

GDPR

Láminas 16–22

Ley 18.331 y comparación internacional

Láminas 23–26

Cierre y gracias

Láminas 27–28

¿Qué es la ciberdelincuencia?

Comprende conductas delictivas que atacan sistemas y datos o que utilizan medios digitales para afectar a las personas y sus bienes.

La tecnología es el objetivo

Ejemplos: acceso ilícito a datos, interceptación de transmisiones y daño informático.

La tecnología es el medio

Ejemplos: fraude, acoso telemático y contacto con menores con finalidad sexual.

Técnica y delito

Phishing y ransomware describen modalidades de ataque. La calificación penal depende de las conductas, la intención y los demás requisitos del tipo aplicable.

Primero se identifican los hechos; después se determina la norma penal.

Norma penal aplicable

Ley 20.327: una respuesta penal y preventiva

Promulgada el 23 de agosto de 2024 y publicada el 25 de septiembre de 2024, establece normas de prevención y represión de la ciberdelincuencia.

Arts. 1 a 8: dimensión penal

Incorpora delitos y agravantes al Código Penal y modifica la normativa sobre lavado de activos.

Art. 9: educación

Prevé una campaña nacional sobre finanzas personales y ciberseguridad.

Arts. 10 y 11: prevención financiera

Autoriza determinados registros interinstitucionales y la inmovilización de fondos bajo condiciones legales.

Los artículos de la Ley 20.327 no deben confundirse con los artículos del Código Penal que incorpora.

Acoso, fraude y suplantación de identidad en Uruguay

La Ley 20.327 incorporó estos delitos al Código Penal. Aquí vemos qué conductas sancionan y cuáles son sus penas básicas.

Acoso telemático - art. 288 BIS

Conducta: vigilar, perseguir o procurar contacto insistente por medios telemáticos, alterando gravemente la vida de la víctima.

Ejemplo: persecución digital reiterada que obliga a cambiar rutinas.

Pena básica: tres meses de prisión a tres años de penitenciaría.

Fraude informático - art. 347 BIS

Conducta: engaños y manipulaciones digitales para obtener un provecho injusto con perjuicio ajeno.

Ejemplo: obtener credenciales mediante engaño para una transferencia no consentida.

Pena básica: remite a la del art. 347, seis meses de prisión a cuatro años de penitenciaría.

Suplantación de identidad - art. 347 TER

Conducta: apropiarse de la identidad digital ajena con intención de dañar.

Ejemplo: usar credenciales de otra persona para perjudicarla.

Pena básica: un año de prisión a seis años de penitenciaría. La creación de nuevos perfiles destinados exclusivamente a la parodia está exceptuada.

Las agravantes se regulan, respectivamente, en los arts. 288 TER, 348 BIS y 348 TER.

Código Penal uruguayo – arts. 288 BIS, 288 TER, 347 BIS, 347 TER, 348 BIS y 348 TER

Delitos contra datos y sistemas informáticos

La Ley 20.327 también incorporó delitos relacionados con accesos, interceptaciones, usos de datos, daños y dispositivos destinados a cometer delitos.

Acceso ilícito - art. 297 BIS

Conducta: sin autorización y sin justa causa, acceder, interferir, difundir, vender o ceder información digital ajena.

Pena: seis a veinticuatro meses de prisión.

Interceptación - art. 297 TER

Conducta: interceptar, interrumpir o interferir técnicamente transmisiones no públicas, sin autorización ni justa causa.

Pena: seis a veinticuatro meses de prisión.

Vulneración de datos - art. 297 QUATER

Conducta: acceder, apropiarse, utilizar o modificar datos confidenciales sin autorización, o difundir, revelar o ceder los datos, hechos o imágenes comprendidos.

Pena: seis a veinticuatro meses de prisión por acceder sin autorización; un año de prisión a cuatro años de penitenciaría por difundir o ceder.

Daño y abuso de dispositivos - arts. 358 QUATER y QUINQUIES

Daño informático: destruir, alterar o inutilizar datos o sistemas, en las condiciones previstas por el delito, con finalidad de causar daño.

Abuso de dispositivos: determinadas conductas ilegítimas relacionadas con programas, sistemas, credenciales o contraseñas destinados inequívocamente a cometer delitos.

Pena de cada figura: seis a veinticuatro meses de prisión.

Las herramientas de seguridad de uso legítimo no se equiparan automáticamente al abuso del art. 358 QUINQUIES.

Código Penal uruguayo – arts. 297 BIS a 297 QUATER, 358 QUATER y 358 QUINQUIES

Grooming: qué exige el art. 277 BIS

El art. 94 de la Ley 19.580 incorporó esta figura al Código Penal. El art. 2 de la Ley 20.327 agregó sus agravantes mediante el art. 277 TER.

Conducta y finalidad

Contactar o influir sobre una persona menor de edad mediante tecnologías, con el propósito de cometer delitos contra su integridad sexual, actos con connotaciones sexuales, obtener material pornográfico u obligarla a actuar contra su voluntad, según el texto legal.

Encuentro físico y pena

El tipo no exige un encuentro presencial. La figura básica prevé seis meses de prisión a cuatro años de penitenciaría.

Agravantes del art. 277 TER

Coacción, intimidación o engaño; afinidad o parentesco; contacto con menores de trece años o en las condiciones de discapacidad previstas por la norma.

Ejemplo hipotético

Una persona adulta manipula a un adolescente mediante mensajes para obtener contenido sexual. Deben acreditarse el contacto, la finalidad y las circunstancias concretas.

Una comunicación ordinaria entre un adulto y un menor no configura por sí sola esta figura.

Código Penal uruguayo · Ley 19.580 · Ley 20.327

Imágenes íntimas: creación y difusión son decisiones distintas

El art. 92 de la Ley 19.580 sanciona difundir, revelar, exhibir o ceder a terceros imágenes o grabaciones íntimas o sexuales sin autorización.

Qué protege

La decisión de una persona sobre la divulgación de su contenido íntimo. Haber participado en las imágenes no habilita a difundirlas.

Pena y protección de menores

La pena es de seis meses de prisión a dos años de penitenciaría. La autorización de una persona menor de dieciocho años no se considera válida a estos efectos.

Sitios y plataformas

El artículo también contempla a administradores de sitios, portales, buscadores o similares que, notificados de la falta de autorización, no retiren inmediatamente el contenido.

Ejemplo hipotético

Una expareja comparte en un grupo una grabación que se realizó de común acuerdo. La aceptación de la grabación no demuestra autorización para compartirla.

Consentir la creación de una imagen no equivale a consentir cualquier difusión posterior.

Ley 19.580

¿Quién interviene ante un ciberdelito en Uruguay?

La investigación penal y la respuesta técnica requieren instituciones con funciones diferentes.

Dirección General de Cibercrimen

Investiga delitos relacionados con tecnologías digitales y recopila y analiza evidencia.

Fiscalía y órganos judiciales

Fiscalía dirige la investigación penal. Los jueces resuelven los asuntos y autorizan las medidas que corresponden.

CERTuy, dentro de Agesic

Es el centro nacional de respuesta a incidentes de seguridad informática. Coordina y apoya la respuesta técnica dentro de su ámbito de actuación.

Denuncia temprana

Conservar mensajes, enlaces, correos y registros. Se puede denunciar con información preliminar y ampliarla después.

La denuncia no necesita esperar a que la víctima reúna toda la prueba.

Autoridades competentes

La evidencia digital cruza fronteras

Un delito ocurrido en Uruguay puede requerir mensajes o registros conservados por un proveedor extranjero. Por eso puede ser necesaria la cooperación internacional.

Qué puede servir como evidencia

Registros de acceso, direcciones IP, correos, mensajes, metadatos y datos de transacciones.

Por qué importa actuar a tiempo

Los registros pueden borrarse, modificarse o dejar de estar disponibles.

Qué límites existen

La preservación evita la pérdida de datos, pero no concede automáticamente su entrega o acceso.

Cómo se interpreta

Una dirección IP es una pista que debe contextualizarse y contrastarse con otros elementos.

Preservar, obtener y valorar la prueba son actuaciones distintas.

Ley 20.004 y Convenio Iberoamericano

La Ley 20.004, promulgada el 25 de noviembre de 2021, aprueba mediante un artículo único el Convenio suscrito en Madrid el 28 de mayo de 2014.

Art. 1 del Convenio

Busca reforzar la cooperación para asegurar y obtener pruebas contra la ciberdelincuencia.

Arts. 3 y 4 del Convenio

Establecen cooperación mutua, motivos de negativa y respeto de los derechos humanos.

Art. 8 del Convenio

Prevé autoridades centrales y puntos de contacto disponibles de forma continuada.

De un registro extranjero a una prueba utilizable

Ejemplo hipotético: una empresa uruguaya necesita registros de acceso conservados por un proveedor en otro Estado. Se presupone un instrumento de cooperación aplicable entre ambos Estados.

1

Identificar y preservar - art. 6 del Convenio

Precisar cuenta, fechas y datos necesarios; solicitar su preservación para evitar el borrado. Preservar no equivale a recibir el contenido.

2

Justificar y canalizar - arts. 8 y 9

La solicitud debe describir hechos, autoridad, eventual calificación y diligencia requerida. Las autoridades centrales canalizan las actuaciones.

3

Obtener por la vía legal - art. 7

La autoridad requerida evalúa requisitos y realiza las diligencias que correspondan. Pueden operar motivos de negativa del art. 3 y garantías del art. 4.

4

Documentar y valorar

Registrar recepción, integridad, accesos y cadena de custodia. Contrastar los registros con otros elementos antes de atribuir el hecho a una persona.

Ni una captura ni una IP aislada sustituyen la obtención lícita y la valoración conjunta de la evidencia.

Convenio Iberoamericano (Madrid, 2014)

Cibercrimen, ciberseguridad y ciberdefensa

Investigar un delito, proteger los sistemas y defender al Estado son tareas diferentes que pueden requerir coordinación.

Investigación del ciberdelito

Busca esclarecer los hechos, reunir evidencia y determinar responsabilidades penales, con las garantías correspondientes.

Ciberseguridad

Previene incidentes, protege sistemas, contiene daños y recupera servicios.

Ciberdefensa

Prepara capacidades del Estado para afrontar amenazas digitales vinculadas con la defensa nacional y la protección de su soberanía.

Un delito internacional no se convierte por ese solo hecho en una cuestión militar.

Ciberdefensa y cibercrimen

Defensa nacional: políticas y protección del ciberespacio.

Estos instrumentos orientan la preparación del Estado frente a amenazas y la protección de su soberanía y sus infraestructuras.

Decreto 129/016: Política Militar de Defensa

Establece orientaciones para preparar y emplear los medios militares. Incluye planificación de capacidades y coordinación entre las Fuerzas Armadas.

Decreto 371/020: Política de Defensa Nacional 2020–2025

Reconoce los ciberataques como una amenaza. Incluye orientaciones sobre protección de la soberanía, valoración de riesgos y coordinación de capacidades del Estado.

Decreto Reservado 44/018: infraestructuras críticas

Está vinculado con el Plan de Seguridad de Infraestructuras Críticas. Su carácter reservado permite conocer su finalidad mediante referencias públicas, pero limita el acceso a sus medidas detalladas.

Estas políticas deben leerse en su contexto temporal y dentro de las competencias legales; no son una autorización general para intervenir sistemas.

Decreto 129/016 · Decreto 371/020 · Decreto Reservado 44/018

Servicios esenciales: un ataque puede tener efectos físicos

Escenario hipotético: un ataque deja sin acceso a sistemas de una red hospitalaria y afecta la coordinación de atención.

Disponibilidad

La información no está accesible cuando se necesita. Ejemplo: no poder consultar una historia clínica.

Integridad

Los datos son alterados. Ejemplo: cambios no autorizados en información que se utiliza para decidir un tratamiento.

Confidencialidad

Personas no autorizadas acceden a información. Ejemplo: exposición de datos de salud.

Respuesta coordinada: los operadores contienen y recuperan; la investigación penal reúne prueba; la autoridad de datos interviene en su ámbito. La dimensión de defensa debe evaluarse según amenaza y competencias.

De la Directiva 95/46/CE al GDPR

El Reglamento General de Protección de Datos es el Reglamento (UE) 2016/679, aprobado el 27 de abril de 2016.

Antes: Directiva 95/46/CE

- Fue el marco europeo precedente de protección de datos personales.
- Era una directiva: cada Estado miembro la incorporaba a su propia ley nacional.
- Resultado: reglas distintas entre países de la UE.

Art. 94 del GDPR

- Deroga la Directiva anterior.
- Las referencias a la Directiva se entienden hechas al GDPR.

Art. 99 del GDPR

- Entró en vigor a los 20 días de su publicación en el Diario Oficial de la UE.
- Se aplica desde el 25 de mayo de 2018.
- Al ser un reglamento, es obligatorio en todos sus elementos y directamente aplicable en todos los Estados miembros.

GDPR y RGPD son las siglas en inglés y español del mismo reglamento. Pasamos de una directiva que cada país adaptaba a una norma común y directamente aplicable.

GDPR: principios para utilizar datos personales

El GDPR establece reglas sobre qué datos puede pedir una organización, para qué puede usarlos y cómo debe protegerlos.

Uso legal, leal y transparente

Contar con una justificación válida y explicar de forma clara quién utiliza los datos y para qué.

Finalidad y datos necesarios

Usar los datos para propósitos determinados y pedir solo lo necesario. Por ejemplo, una entrega requiere una dirección, pero no cualquier información personal adicional.

Datos correctos y conservación limitada

Corregir errores y conservar los datos durante el tiempo justificado por su finalidad y las obligaciones aplicables.

Seguridad y responsabilidad demostrable

Proteger los datos y poder demostrar las medidas y decisiones adoptadas.

La privacidad afecta al diseño del servicio desde que se decide qué información pedir.

El responsable decide los fines y medios del tratamiento. El encargado trata los datos por cuenta del responsable y siguiendo sus instrucciones.

GDPR, artículos 4 y 5

GDPR: motivos legales para utilizar nuestros datos

Cada uso de datos personales necesita una justificación legal. El consentimiento es una de las seis posibilidades.

Consentimiento y contrato

Consentimiento: la persona autoriza libremente un uso concreto de sus datos.

Contrato: los datos son necesarios para cumplir lo acordado, como usar una dirección para entregar una compra.

Obligación legal e interés público

Obligación legal: una norma exige utilizar o conservar determinados datos.

Interés público: los datos son necesarios para una tarea respaldada por el Derecho de la UE o de un Estado miembro.

Intereses vitales e interés legítimo

Intereses vitales: los datos son necesarios para proteger la vida de una persona.

Interés legítimo: existe una finalidad válida y un uso necesario, que debe evaluarse frente a los derechos de las personas.

Consentimiento válido

La persona debe elegir libremente y comprender qué autoriza. La organización debe poder demostrar la autorización y permitir retirarla. El silencio y las casillas premarcadas no equivalen a aceptar.

Los datos sensibles, como los de salud o las creencias religiosas, requieren cumplir condiciones adicionales de protección.

GDPR, artículos 6, 7 y 9

Información, acceso, rectificación y supresión

Los derechos se comprenden mejor como solicitudes que una persona puede dirigir al responsable.

Arts. 13 y 14: información

¿Quién utiliza mis datos, para qué, con qué base y durante cuánto tiempo? La organización debe informar según cómo obtuvo los datos.

Art. 15: acceso

Quiero saber si tratan mis datos y obtener acceso e información sobre su uso.

Art. 16: rectificación

Mi información es inexacta o incompleta y quiero corregirla.

Art. 17: supresión

Quiero que eliminen datos cuando concurra una causa legal. No es absoluto: puede haber obligaciones de conservación y otras excepciones.

Ejemplo hipotético: una persona puede pedir corregir su dirección; borrar toda la documentación de una compra puede requerir otro análisis.

GDPR – arts. 13 a 17

Limitar, trasladar, oponerse y pedir garantías

Cada derecho tiene condiciones. El responsable debe facilitar su ejercicio y explicar las decisiones.

Art. 18: limitación

Pedir que ciertos usos se suspendan en los supuestos previstos, por ejemplo mientras se verifica una impugnación de exactitud.

Art. 20: portabilidad

Recibir datos facilitados por la persona en formato estructurado y transmitirlos, cuando el tratamiento automatizado se base en consentimiento o contrato.

Arts. 21 y 22

Oponerse a determinados tratamientos; el marketing directo tiene una regla específica de oposición. El art. 22 protege frente a ciertas decisiones exclusivamente automatizadas con efectos significativos, con excepciones y garantías.

Art. 12: respuesta

Como regla, responder dentro de un mes. Puede ampliarse dos meses por complejidad o número de solicitudes, informando y justificando dentro del primer mes.

Ejemplo: pedir trasladar datos no significa que cualquier información interna de una empresa sea portable.

GDPR – Reglamento (UE) 2016/679

GDPR: cuándo puede aplicarse fuera de la Unión Europea

La ubicación de una organización no es el único criterio: importa la conexión de su actividad con la Unión Europea.

Tratamiento vinculado con un establecimiento en la UE

La empresa tiene una sede, filial o representación en la UE y trata datos en el marco de sus actividades.

Oferta dirigida a personas que se encuentran en la UE

La empresa ofrece bienes o servicios a personas que están en la UE, aunque no tenga presencia allí.

Seguimiento de su comportamiento cuando ocurre en la UE

La empresa observa o analiza el comportamiento de personas cuando ese comportamiento ocurre en la UE.

Ejemplo: una empresa uruguaya que dirige sus servicios a personas que se encuentran en España puede quedar alcanzada por el GDPR.

La nacionalidad europea de una persona o la mera accesibilidad de una web desde Europa no resuelven, por sí solas, la aplicación.

GDPR, artículo 3

GDPR: protección de datos y respuesta ante incidentes

Una brecha es un incidente que provoca pérdida, destrucción o alteración accidental o ilícita de datos personales, o su acceso o divulgación no autorizados.

Proteger los datos desde el diseño

Incorporar la protección al crear el servicio, limitar el uso de datos a lo necesario y aplicar medidas de seguridad adecuadas al riesgo.

Avisar a la autoridad de protección de datos

Cuando corresponda, comunicar la brecha sin demora indebida y, de ser posible, dentro de las 72 horas desde que se tiene constancia. Se exceptúan los casos en que es improbable que exista riesgo para los derechos y libertades de las personas.

Informar a las personas afectadas

Cuando sea probable un alto riesgo, comunicarles la brecha sin demora indebida, con las excepciones previstas.

Sanciones según la infracción

Las multas dependen del incumplimiento y sus circunstancias. La categoría superior puede alcanzar 20 millones de euros o, para una empresa, el 4 % de su volumen de negocio anual mundial del ejercicio anterior, la cifra mayor.

No toda brecha exige las mismas comunicaciones ni produce automáticamente la multa máxima.

GDPR, artículos 25, 32, 33, 34 y 83

Ley 18.331: obligaciones cotidianas

Una organización debe justificar y organizar el tratamiento de los datos de clientes, trabajadores y otras personas comprendidas en su actividad.

Art. 9: consentimiento y excepciones

Determinar si necesita consentimiento o si concurre una excepción legal. No asumir que tener un dato autoriza cualquier uso.

Art. 13: información

Informar finalidad, destinatarios, responsable, carácter obligatorio o facultativo de los datos y derechos, entre otros extremos legales.

Arts. 10 y 12: seguridad y responsabilidad

Adoptar medidas técnicas y organizativas apropiadas, con responsabilidad proactiva. Ejemplo: definir permisos y revisar quién accede a datos de clientes.

Arts. 14 y 15: derechos

Atender acceso y solicitudes de rectificación, actualización, inclusión o supresión según los supuestos y límites legales.

Ejemplo: recolectar datos para prestar un servicio exige explicar su uso y protegerlos durante su conservación.

Ley 18.331

Ley 18.331: transferencias e incidentes

La URCDP es la Unidad Reguladora y de Control de Datos Personales. La protección incluye el destino de los datos y la respuesta a vulneraciones.

Art. 23: transferencias

Analizar el nivel de protección del destino y los mecanismos o excepciones legales. Un proveedor extranjero exige revisar el flujo y sus garantías.

Decreto 64/020, art. 4

El responsable comunica a la URCDP las vulneraciones de seguridad que incidan en la protección de datos en un máximo de 72 horas desde que las conoce.

Contenido práctico

Identificar qué ocurrió, cuándo se conoció, datos y personas afectadas, consecuencias y medidas adoptadas. Documentar el proceso.

Si también aplica el GDPR

Su art. 33 distingue según riesgo y su art. 34 según alto riesgo para las personas. Los requisitos de un régimen no deben trasladarse automáticamente al otro.

La denuncia penal, la comunicación a la autoridad de datos y la recuperación técnica cumplen funciones distintas.

Ley 18.331 · Decreto 64/020 · GDPR

Protección de datos en la UE, España y el Reino Unido

La UE comparte un reglamento; España lo complementa con su legislación nacional y el Reino Unido tiene un régimen propio.

Unión Europea: GDPR

Establece principios para utilizar datos personales, reconoce derechos y fija obligaciones de seguridad y respuesta ante brechas. Las autoridades de protección de datos supervisan su cumplimiento.

España: GDPR y LOPDGDD

La LOPDGDD complementa el marco europeo y desarrolla derechos digitales. Incluye la desconexión digital laboral, vinculada con el respeto del descanso fuera del tiempo de trabajo.

Reino Unido: UK GDPR y DPA 2018

Cuenta con un régimen propio de protección de datos. La Data (Use and Access) Act 2025 modifica ese marco, sin sustituir el UK GDPR ni la DPA 2018.

El uso de nombres parecidos no elimina las diferencias entre el marco de la UE y el británico.

GDPR, arts. 3, 15 a 22, 32 a 34; LOPDGDD arts. 5, 7 y 88; UK GDPR y DPA 2018 · Autoridades: AEPD y autoridades autonómicas; ICO

Canadá y Estados Unidos: a quién se aplica cada norma

PIPEDA se ocupa principalmente de actividades comerciales del sector privado; la Privacy Act estadounidense se centra en determinados registros de agencias federales.

Canadá: PIPEDA y actividades comerciales

Establece obligaciones sobre la recogida, el uso y la protección de datos personales en las actividades comprendidas. También deben considerarse las leyes provinciales aplicables.

Canadá: incidentes y supervisión

Exige reportar y notificar determinadas brechas cuando generan un riesgo real de daño significativo. Interviene el Comisionado de Privacidad federal dentro del ámbito de PIPEDA.

Estados Unidos: Privacy Act of 1974

Regula determinados registros personales de agencias federales. Establece condiciones para su divulgación y permite solicitar acceso y correcciones, con los requisitos y excepciones aplicables.

Aclaración

La Privacy Act de 1974 no es una ley general para todas las empresas privadas estadounidenses.

Antes de comparar derechos o plazos, comprobar si la organización está comprendida por la norma.

PIPEDA · Privacy Act of 1974 · 5 U.S.C. § 552a (apartados (b), (d) y (e))

Respuesta al caso inicial

Atacante extranjero, empresa uruguaya y datos vinculados a la UE: un mismo incidente activa preguntas en varios ámbitos.

Investigar

Cibercrimen y Fiscalía actúan según sus competencias; la prueba extranjera puede requerir cooperación.

Restablecer y proteger

La respuesta técnica busca contener el daño y recuperar los servicios, preservando evidencia.

Cumplir las normas de datos

Se analiza la Ley 18.331 y, si existe la conexión territorial correspondiente, el GDPR.

Evaluar la dimensión de defensa

La intervención de ese ámbito exige analizar la naturaleza de la amenaza y las competencias legales.

La respuesta exige coordinación: persecución penal, cooperación, seguridad, defensa cuando corresponda y derechos de las personas.

Ley 18.331 · GDPR

Gracias

Web realizada por el equipo

https://ciberobservatorio-grupo4.onrender.com/index.html?v=3#/